TÓM TẮT NỘI DUNG ĐỒ ÁN

Phần mềm độc hại trên nền tảng Windows ngày càng gia tăng về số lượng và mức độ tinh vi, trong khi phương pháp phát hiện dựa trên chữ ký không thể nhận diện các biến thể mới chưa từng được ghi nhận. Hai hướng tiếp cận phổ biến hiện nay là phân tích tĩnh và phân tích động. Phân tích tĩnh cho phép phân loại nhanh dựa trên đặc trưng cấu trúc tệp nhưng dễ bị vô hiệu hóa bởi kỹ thuật đóng gói và làm rối mã, trong khi phân tích động quan sát được hành vi thực tế nhưng tốn nhiều tài nguyên hơn. Mỗi hướng tồn tại hạn chế khi đứng độc lập.

Đồ án lựa chọn hướng kết hợp cả hai phương pháp. Giai đoạn tĩnh kế thừa bộ đặc trưng PE 2.381 chiều theo chuẩn EMBER, huấn luyện mô hình LightGBM trên tập dữ liệu tự thu thập và tổng hợp từ nhiều nguồn công khai, đồng thời áp dụng kỹ thuật giảm chiều theo bài báo tham khảo ở ba ngưỡng 128, 256 và 384. Giai đoạn động sử dụng Sysmon và SilkETW làm công cụ thu thập sự kiện trong môi trường sandbox xây dựng trên VirtualBox, từ đó thiết kế và cài đặt toàn bộ các module xử lý phía sau gồm chuẩn hóa sự kiện, xây dựng chuỗi hành vi, trích xuất chỉ số xâm phạm, dựng cây tiến trình và ánh xạ tự động sang khung MITRE ATT&CK.

Đóng góp chính của đồ án là một pipeline phân tích phần mềm độc hại tự động hoàn chỉnh, vận hành từ khâu nhận tệp đầu vào đến khâu xuất báo cáo kết quả mà không yêu cầu can thiệp thủ công. Trên cơ sở kế thừa các công cụ và chuẩn mở sẵn có, đồ án tập trung vào việc thiết kế kiến trúc tổng thể, phát triển các module tích hợp và xây dựng pipeline hoàn chỉnh. Hệ thống được kiểm thử trên nhiều tập dữ liệu độc lập thuộc nhiều họ phần mềm độc hại khác nhau, kết quả thực nghiệm được trình bày chi tiết trong Chương **??**.

Sinh viên thực hiện
Nguyễn Xuân Bách